



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-43059 Bluetooth: MGMT: Fix list corruption and UAF in command complete handlers

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-10
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-43059 Bluetooth: MGMT: Fix list corruption and UAF in command complete handlers - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-10 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

`CVE-2026-43059` is a Linux kernel Bluetooth management (`MGMT`) memory-safety vulnerability in `net/bluetooth/mgmt.c` that was published on 2026-05-05. Public records agree that a prior rework of `mgmt\_pending\_valid()` changed how pending Bluetooth management commands are unlinked, and several command-completion handlers were not updated to match the new semantics. The result is a pair of residual bugs that can trigger double `list\_del()` corruption and use-after-free conditions in Bluetooth command-complete paths.

This is not an internet-scale unauthenticated remote exploit based on the reviewed evidence. The published CVSS vectors describe a local attack path with low privileges and no user interaction. Operationally, the highest-risk environments are Linux hosts that run affected kernel branches, have the Bluetooth subsystem active, and expose the Bluetooth management path to local users, administrators, containerized workloads with elevated capabilities, or adjacent tooling that can drive MGMT operations.

The public source set does not confirm in-the-wild exploitation, CISA KEV inclusion, or a public proof-of-concept as of 2026-06-10. Even so, defenders should not dismiss the issue as routine housekeeping: kernel list corruption and use-after-free bugs can produce crashes, denial of service, and potentially broader impact depending on exploitability and local hardening. The immediate defensive priorities are to identify affected kernel versions, apply vendor-supported kernel updates, reduce unnecessary Bluetooth exposure on servers and appliances, and monitor kernel logs for Bluetooth MGMT crash indicators while patching is underway.

2. Intelligence Requirement

This report addresses the following intelligence requirement: what does `CVE-2026-43059` mean for defenders running Linux systems, which kernel versions and deployment conditions are exposed, what does the public record say about exploitation and impact, and what should security and platform teams do immediately?

Question	Assessment
What is the flaw?	A Linux kernel Bluetooth MGMT logic error in command-completion handlers after `mgmt_pending_valid()` changed semantics, leaving paths that can corrupt linked lists or free pending commands incorrectly.
What is the likely security outcome?	At minimum, kernel panic / denial of service from list corruption or use-after-free; broader kernel-memory-compromise risk cannot be ruled out from the public CVSS scoring alone.
Is the attack remote?	The reviewed authoritative records score the attack vector as local, not network-remote.
What access is required?	NVD and Ubuntu publish `PR:L`, indicating low privileges are sufficient in the modeled attack path.
Which component is affected?	Linux kernel Bluetooth management logic in `net/bluetooth/mgmt.c`.
What versions are affected?	NVD lists affected ranges across Linux kernel branches including `6.6.140` to before `6.7`, `6.12.59` to before `6.12.78`, `6.16.10` to before `6.17`, `6.17` / early `6.18` branch exposure, `6.19` to before `6.19.10`, and `7.0-rc1` through `7.0-rc4`.
Is there confirmed active exploitation?	No reviewed authoritative source confirmed in-the-wild exploitation or KEV inclusion as of 2026-06-10.
What matters most to defenders?	Kernel and distro-version inventory, Bluetooth subsystem exposure review, rapid patching through vendor errata, and crash-log

	hunting for Bluetooth MGMT memory-corruption indicators.
--	--

3. Source Review and Confidence

Source	Contribution	Confidence
Microsoft Security Update Guide entry	Initial intake source and publication tracking reference.	Medium
CVE Program CNA record (Linux)	Canonical upstream description, affected file path, git-version ranges, semver notes, and original publication/update timestamps.	High
NVD JSON 2.0 / detail page	Public normalized record with CVSS v3.1 `7.8 High`, `CWE-416`, affected semver ranges, and stable-fix references.	High
Ubuntu CVE page	Corroborates the NVD-style `7.8 High` local vector and provides distro tracking context.	High
Red Hat security data API / Bugzilla reference	Adds downstream enterprise impact framing, package-state context, and a more conservative `5.5 Moderate` availability-heavy interpretation.	High
CISA KEV catalog	Negative-evidence check only; `CVE-2026-43059` was absent from the 2026-06-09 catalog snapshot reviewed for this task.	Medium
GitHub Advisory Database	Confirms publication mirroring, the absence of package-version mapping in GitHub's ecosystem model, and a low EPSS estimate of `0.015%`.	Medium

Confidence is high that the vulnerability exists, affects Linux kernel Bluetooth MGMT command-complete handling, and can produce kernel memory-safety failures on affected branches because those points are directly supported by the Linux CNA record, NVD, Ubuntu, and Red Hat. Confidence is moderate on the practical upper bound of impact because the public record contains a scoring discrepancy: NVD and Ubuntu rate the issue `7.8 High` with confidentiality, integrity, and availability impact, while Red Hat frames it as `5.5 Moderate` and emphasizes denial of service. Confidence is low on exploit maturity because the reviewed source set did not identify a public exploit, public exploit-development discussion with reproduction steps, or named threat activity.

4.1 Core Vulnerability Metadata

Field	Value
CVE	`CVE-2026-43059`
Component	Linux kernel Bluetooth management subsystem (`net/bluetooth/mgmt.c`)
Vulnerability class	Memory-safety flaw involving list corruption and use-after-free in command complete handlers
Public weakness mapping	NVD / Ubuntu: `CWE-416` Use After Free; Red Hat: `CWE-825`

	Expired Pointer Dereference framing
NVD severity	`7.8 High`
NVD / Ubuntu vector	`CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H`
Red Hat severity	`5.5 Moderate`
Red Hat vector	`CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H`
Published	CNA: `2026-05-05`; NVD analyzed publication timestamp: `2026-05-05T16:16:14.927`
Last updated in reviewed upstream records	CNA: `2026-05-23`; NVD: `2026-05-22`
Public exploitation status	No reviewed source confirmed active exploitation
KEV status	Not present in the reviewed CISA KEV catalog snapshot dated `2026-06-09`
EPSS reference	GitHub Advisory Database displayed `0.015%`

4.2 Technical Mechanism and Affected Branches

The Linux CNA and NVD descriptions attribute the issue to semantic changes introduced by commit `302a1f674c00` ("Bluetooth: MGMT: Fix possible UAFs"). After that change, `mgmt\_pending\_valid()` both validated the pending command and unlinked it from the pending list. Several completion handlers still behaved as if they needed to unlink or iterate pending entries themselves.

Two residual bug paths are described publicly:

Fault path	Publicly described effect	Defensive implication
`mgmt_add_adv_patterns_monitor_complete()` success path still called `mgmt_pending_remove()` after `mgmt_pending_valid()` had already unlinked the command	Double `list_del()` leading to list corruption and potential kernel panic	Systems using affected Bluetooth management flows can crash under malicious or malformed command sequencing
`set_mesh_complete()` error path continued to use `mgmt_pending_foreach()`	Could target other pending mesh commands and free them while still in concurrent use, creating use-after-free conditions	Bluetooth mesh / pending-command concurrency paths deserve particular patch priority and crash-log review

NVD lists the following affected kernel-version windows in public semver form:

Branch / range from NVD	Public status
`6.6.140` to before `6.7`	Affected
`6.12.59` to before `6.12.78`	Affected
`6.16.10` to before `6.17`	Affected
`6.17` and early subsequent branch coverage reflected by NVD's separate `6.17.1` to before `6.18.20` range	Affected
`6.19` to before `6.19.10`	Affected

`7.0-rc1` through `7.0-rc4`	Affected
-----------------------------	----------

NVD also lists stable-fix reference commits at the following kernel.org URLs, which are useful pivots for patch validation in vendor backports and source-based environments:

Stable fix reference	Value
Stable backport reference 1	`02023ff760cc104a5d86a82ef5b8dd89098ad78d`
Stable backport reference 2	`17f89341cb4281d1da0e2fb0de5406ab7c4e25ef`
Stable backport reference 3	`695b45b2262fcb5e71bed1175aad59c72f92aa78`
Stable backport reference 4	`b5c5e96f3b0a5003c3ff98ebb33e59afec51dd77`

4.3 Analyst Findings

- The best-supported attack model is local abuse against the Bluetooth management path, not a broad remote internet exploit. Exposure therefore depends heavily on host role, Bluetooth usage, and local privilege boundaries.
- Multi-user Linux workstations, developer laptops, kiosks, OT/IoT systems with Bluetooth enabled, and appliances using mesh or advertising-management features deserve more attention than headless servers with Bluetooth fully disabled.
- The severity disagreement between NVD/Ubuntu and Red Hat should be treated as a signal to avoid overclaiming impact. Public evidence clearly supports crash and memory-corruption risk; public evidence does not clearly prove a reliable privilege-escalation exploit chain.
- Red Hat's package-state data indicates `RHEL 6`, `RHEL 7`, and `RHEL 8` kernel tracks reviewed in its advisory were not affected, while `RHEL 9` and `RHEL 10` were marked `Fix deferred` at review time. Downstream distro posture therefore varies materially by branch.
- Because the bug sits in kernel Bluetooth management logic, conventional network IOC-based threat hunting is weak. Exposure discovery, crash telemetry, and Linux hardening review are more valuable than searching for static payload artifacts.

5. Threat Context

The most plausible attack path begins with a low-privileged local user or local execution context on an affected Linux system that can interact with the Bluetooth management subsystem. In enterprise environments, that could mean a user session on a workstation, a compromised account on a shared Linux host, privileged containerized workloads that retain sensitive capabilities, or operational tooling that can issue Bluetooth management actions on endpoints or embedded systems.

The defensive importance of the CVE depends on what the host does. On a hardened server with Bluetooth disabled and no dependent hardware or service path, practical exposure may be low. On laptops, engineering workstations, field devices, medical or industrial endpoints, and embedded Linux systems that actively use Bluetooth controllers, advertising-monitor logic, or mesh-related features, the crash surface is more relevant. In those environments, an attacker may be able to induce denial of service or attempt deeper kernel-memory exploitation against a local target.

No reviewed source tied `CVE-2026-43059` to a named intrusion set, ransomware operator, or known exploit campaign, and the CISA KEV catalog did not include the issue at assessment time. The strongest ATT&CK-aligned mapping that the public record supports is therefore narrow and local:

Tactic	Technique	Relevance
Privilege Escalation	`T1068` Exploitation for Privilege Escalation	Best-fit ATT&CK mapping when a local actor targets a kernel memory-safety flaw to gain elevated execution beyond initial privileges. This remains a plausible exploitation category rather than a publicly confirmed post-condition for this CVE.

Impact	`T1499` Endpoint Denial of Service	Moderate-confidence impact mapping because the public source set explicitly supports kernel panic / service interruption outcomes.
--------	------------------------------------	--

Where ATT&CK confidence is limited, defenders should focus more on host hardening and patch validation than on actor attribution or campaign clustering.

6. Detection and Hunting

Detection engineering for `CVE-2026-43059` should assume limited exploit-specific telemetry. The public record does not publish a stable proof-of-concept or deterministic event signature. The most effective monitoring strategy is layered:

- identify Linux hosts running vulnerable kernel branches
- prioritize systems with Bluetooth enabled or required by business function
- watch for kernel panics, `list\_del` corruption, KASAN-style use-after-free traces, or stack frames referencing Bluetooth MGMT completion functions
- review local privilege boundaries around Bluetooth tooling, `CAP\_NET\_ADMIN`, and any management utilities that can exercise the affected subsystem
- validate vendor errata rather than assuming upstream kernel-version strings map directly to packaged enterprise kernels

6.1 Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Linux kernel versions matching affected public ranges or vendor-advisory equivalents	Vulnerability management, CMDB, EDR software inventory, package inventory	Identify systems that require patching or branch-specific exception review
Bluetooth-enabled hosts on vulnerable kernel branches	Asset inventory, `lsmod`/service inventory, hardware inventory, EDR enrichment	Prioritize systems where the vulnerable subsystem is operationally reachable
Kernel messages containing `list_del corruption`, `BUG: KASAN: use-after-free`, `kernel panic`, `mgmt_add_adv_patterns_monitor_complete`, or `set_mesh_complete`	Syslog, journald forwarding, EDR kernel telemetry	Detect likely crash attempts or post-crash indicators tied to the affected logic
Local users, service accounts, or containers retaining unusual capabilities around Bluetooth or network administration	Auditd, EDR process telemetry, container runtime logs	Reduce likely exploit paths and investigate high-risk local contexts
Vendor branches marked `Fix deferred` or not yet remediated	Distro security advisories, patch dashboards	Prevent false assumptions that package maintainers have already backported the fix

6.2 Example Sigma Logic

```

title: Linux Kernel Bluetooth MGMT Memory Corruption Indicators
id: 1c1f0db3-631f-4e38-9c5f-cve-2026-43059-hunt
status: experimental
description: Hunts for Linux kernel log indicators that may align with CVE-2026-43059 crash or memory-corruption activity in Bluetooth MGMT command-complete paths.
logsource:
  product: linux
  service: kernel
detection:
  selection_keywords:
    message|contains:
      - 'Bluetooth: MGMT'
      - 'mgmt_add_adv_patterns_monitor_complete'

```

```

- 'set_mesh_complete'
- 'list_del corruption'
- 'BUG: KASAN: use-after-free'
- 'kernel panic'
- 'net/bluetooth/mgmt.c'
condition: selection_keywords
falsepositives:
- benign crash-reproduction testing in lab environments
- unrelated Bluetooth debugging or noisy kernel instrumentation
level: medium

```

6.3 Example KQL Hunt Queries

Exposure inventory pivot:

```

DeviceTvmSoftwareInventory
| where OSPlatform =~ "Linux"
| where SoftwareName has_any ("kernel", "Linux Kernel")
| project DeviceName, SoftwareName, SoftwareVersion, EndOfSupportStatus
| order by DeviceName asc

```

Kernel-crash hunting pivot:

```

Syslog
| where TimeGenerated > ago(30d)
| where Facility in ("kern", "daemon") or ProcessName in ("kernel", "systemd-journald")
| where SyslogMessage has_any (
    "Bluetooth: MGMT",
    "mgmt_add_adv_patterns_monitor_complete",
    "set_mesh_complete",
    "list_del corruption",
    "BUG: KASAN: use-after-free",
    "kernel panic",
    "net/bluetooth/mgmt.c"
)
| project TimeGenerated, Computer, HostName, ProcessName, SeverityLevel, SyslogMessage
| order by TimeGenerated desc

```

Capability / privileged-process review pivot:

```

DeviceProcessEvents
| where Timestamp > ago(30d)
| where InitiatingProcessCommandLine has_any ("bluetoothctl", "btmgmt", "hciconfig")
    or ProcessCommandLine has_any ("bluetoothctl", "btmgmt", "hciconfig")
| project Timestamp, DeviceName, FileName, ProcessCommandLine, InitiatingProcessAccountName,
InitiatingProcessParentFileName
| order by Timestamp desc

```

6.4 Suggested Hunt Questions

- Which Linux endpoints still run kernels in the affected public ranges or vendor-equivalent vulnerable builds?
- On those hosts, is Bluetooth enabled, required, or reachable by non-administrative local users or semi-privileged service contexts?
- Have any endpoints logged `list\_del` corruption, KASAN use-after-free traces, or Bluetooth MGMT stack references since the CVE publication window?
- Do any container or appliance workloads retain unnecessary capabilities that could increase local exploitability against kernel subsystems?
- Are security and platform teams tracking distro branch status closely enough to catch `Fix deferred` states instead of assuming generic kernel-version parity?

7. Recommendations

Priority	Owner	Action
Critical	Platform Engineering / Linux Operations	Apply vendor-supported kernel updates that incorporate the upstream Bluetooth MGMT

		fix references listed in Section 4, and reboot affected systems on a controlled schedule.
Critical	Vulnerability Management	Inventory Linux systems by exact kernel package version and distro branch; treat generic upstream semver ranges as starting points, then validate against vendor errata and backport notes.
High	Endpoint / Infrastructure Operations	Prioritize workstations, embedded devices, kiosks, and other Bluetooth-enabled endpoints ahead of headless systems where Bluetooth is disabled or absent.
High	Security Engineering	Disable or restrict Bluetooth services and tooling on servers and appliances where Bluetooth is not a business requirement.
High	Detection Engineering / SOC	Add temporary hunts for Bluetooth MGMT crash indicators in kernel logs and alert on unusual kernel panic clusters affecting Bluetooth-enabled Linux fleets.
High	Identity / Platform Security	Review local privilege boundaries, capability assignments, and container configurations that might let low-privilege contexts exercise sensitive kernel interfaces.
Medium	Red Hat / Enterprise Linux Administrators	Review `Fix deferred` package states for `RHEL 9` and `RHEL 10` and track errata release timing instead of assuming immediate coverage.
Medium	Threat Intelligence	Re-check KEV, distro advisories, and exploit reporting during subsequent patch cycles in case public weaponization or stronger exploitation evidence emerges.

Additional analyst guidance:

- Where patching must wait for maintenance windows, reduce risk by disabling unnecessary Bluetooth functionality and limiting who or what can exercise management tooling on the host.
- Use crash telemetry as a compensating detective control, but do not rely on it as prevention; memory-corruption bugs can fail noisily or silently depending on code path and hardening.
- If suspicious Bluetooth-related kernel crashes are found on unpatched systems, preserve kernel logs, panic traces, and host context for deeper forensic review rather than simply rebooting and moving on.

8. References

1. Microsoft Security Update Guide: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-43059>
2. CVE Program CNA record: <https://cveawg.mitre.org/api/cve/CVE-2026-43059>
3. NVD detail page: <https://nvd.nist.gov/vuln/detail/CVE-2026-43059>
4. NVD JSON 2.0 API query: <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-43059>
5. Ubuntu CVE page: <https://ubuntu.com/security/CVE-2026-43059>

6. Red Hat security data API: <https://access.redhat.com/hydra/rest/securitydata/cve/CVE-2026-43059.json>
7. Red Hat Bugzilla entry `2466796`: https://bugzilla.redhat.com/show_bug.cgi?id=2466796
8. CISA Known Exploited Vulnerabilities catalog JSON:
https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
9. GitHub Advisory Database entry `GHSA-9xxq-2x8g-75gf`: <https://github.com/advisories/GHSA-9xxq-2x8g-75gf>
10. Stable-fix reference 1: <https://git.kernel.org/stable/c/02023ff760cc104a5d86a82ef5b8dd89098ad78d>
11. Stable-fix reference 2: <https://git.kernel.org/stable/c/17f89341cb4281d1da0e2fb0de5406ab7c4e25ef>
12. Stable-fix reference 3: <https://git.kernel.org/stable/c/695b45b2262fcb5e71bed1175aad59c72f92aa78>
13. Stable-fix reference 4: <https://git.kernel.org/stable/c/b5c5e96f3b0a5003c3ff98ebb33e59afec51dd77>